

Demystifying the Kerberos Authentication Process

Kerberos is a network security protocol that authenticates the service requests between multiple hosts across untrusted networks. It is an authentication mechanism, which uses symmetric key encryption while transferring the information between Kerberos components. This article describes the Kerberos authentication process in detail.



Kerberos infrastructure components

Kerberos has a key distribution centre (KDC), which has authentication and ticket granting services running in it. The authentication service is termed 'AS' while the ticket granting service is called 'TGS'.

The Kerberos infrastructure consists of the following components.

- **Authentication server (AS):** This is the component responsible for authenticating the client.
- **Ticket Granting Service [TGS]:** This intermediary component grants access to the service on the network, after verification of the client based on authentication from AS.
- **Client:** This is the machine that needs to access and avail the service on the network.
- **Service on the network:** This refers to services like the file server shared in the network for an authenticated client.

Authentication process details

The Kerberos authentication process can be split into stages for simplicity. These are as follows:

- Client authentication with KDC
- Client authentication with AS
- Client request with KDC (TGS) for service
- Client service communication

We will analyse the mechanisms at the end of stage 3, and the key distribution status at each stage for each component, to better understand

Primarily, Kerberos provides third-party authentication for users, machines and services that are using it.

Going through this article will be pretty easy if you are familiar with:

- Types of encryptions and the keys associated with them
- The basics and purpose of SSO (single sign-on)
- Importance of authentication in the security context

During the authentication process, the Kerberos infrastructure uses various keys. Given below is a list of such keys and how they are termed in

this document.

Client-LongLivedKey: Symmetric key for client. Only AS and client will have this key.

TGS-LongLivedKey: Symmetric key for TGS. Only AS and TGS will have this key.

Service-LongLivedKey: Symmetric key for service. Only TGS and service will have this key.

TGS-SessionKey: Symmetric key to be used for sessions between client and TGS.

Service-SessionKey: Symmetric key to be used for sessions between client and service.